ICS 35.040
CCS A 11

中华人民共和国国家标准

GB/T 42927—2023

金融行业开源软件测评规范

Financial industry open source software evaluation specification

2023-08-06 发布　　2023-08-06 实施

国家市场监督管理总局
国家标准化管理委员会　发布

目　　次

前言 …… Ⅲ
1　范围 …… 1
2　规范性引用文件 …… 1
3　术语和定义 …… 1
4　缩略语 …… 1
5　金融行业开源软件测评体系 …… 2
6　金融行业开源软件测评模型 …… 3
6.1　开源许可证 …… 3
6.2　行业认可度 …… 4
6.3　产品活力 …… 4
6.4　服务支持 …… 5
6.5　安全性 …… 6
6.6　兼容性 …… 7
6.7　可维护性 …… 7
6.8　可扩展性 …… 7
6.9　功能性 …… 8
6.10　可靠性 …… 8
6.11　易用性 …… 9
6.12　性能效率 …… 9
7　金融行业开源软件测评方法 …… 10
7.1　说明 …… 10
7.2　权重设定 …… 10
7.3　评分计算 …… 10
7.4　等级评价 …… 11
参考文献 …… 12

前　言

本文件按照GB/T 1.1—2020《标准化工作导则　第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由全国金融标准化技术委员会(SAC/TC 180)归口。

本文件起草单位：中国互联网金融协会、中国建设银行股份有限公司、中国工商银行股份有限公司、中国农业银行股份有限公司、中国银联股份有限公司、交通银行股份有限公司、招商银行股份有限公司、中信银行股份有限公司、上海银行股份有限公司、深圳前海微众银行股份有限公司、中国人寿保险(集团)公司、国泰君安证券股份有限公司、中互金认证有限公司、北京银联金卡科技有限公司、华为技术有限公司、证通股份有限公司、深圳市腾讯计算机系统有限公司、蚂蚁科技集团股份有限公司、北京国家金融标准化研究院有限责任公司、北京金融科技产业联盟、北京国家金融科技认证中心有限公司。

本文件主要起草人：杨农、何红滢、沈一飞、杨彬、刘绪光、付大源、张维凡、金磐石、李鑫、郭贞、袁巍、牟宁波、徐翥、孙刚、闫冬梅、刘阳、闫晓林、赖强、岳松颂、刘建珍、姜晓璇、孙权、周雍恺、赵庆杭、王琪、蒋丹妮、白宗杰、王冠雄、罗文江、李霞、王丽丽、姜建成、钟燕清、董亮、俞枫、刘传友、张忍、刘志刚、李增局、史汝辉、王鑫、白阳、符海芳、马全一、李永乐、李茂雨、周凌、李克鹏、单致豪、代威、蒋增增、陆碧波、彭晋、边思康、王旭、付辉、李家琪、陈达炜、贺宇、唐卓、胡达川、张海燕、李振、冯晓文。

金融行业开源软件测评规范

1 范围

本文件规定了金融行业开源软件测评体系和对应的测评模型与测评方法。

本文件适用于规范金融机构开源软件引入评估选型及开源软件测评工作。

2 规范性引用文件

本文件没有规范性引用文件。

3 术语和定义

下列术语和定义适用于本文件。

3.1

开源软件 open source software

一种可以获取源代码的计算机软件。

注：这种软件的著作权持有人通过开源许可证将软件的复制、修改、再发布的权利向公众开放。

3.2

开源许可证 open source license

用于规范受著作权保护的软件在规定条款、条件下被使用或分发等行为的许可证。

注：一般指具备广泛认可性的、具有法律性质的协议，也称开源协议，目的是减少作者及用户针对开源软件权责的法律解释成本。常见开源许可证有通用公共许可证(GNU General Public License，GPL)、Mozilla 公共许可证(Mozilla Public License，MPL)、BSD 许可证(Berkeley Software Distribution license，BSD License)等。

3.3

衍生品 derivative work

基于开源代码进行再次创作的作品。

注：包括对全部或部分开源代码进行修改、重写、翻译、注释、组合或与之链接(包括动态链接或静态链接)而形成的作品。通过进程间通信或系统调用源代码的作品视为独立作品，不属于衍生品。

3.4

贡献者 contributor

对开源软件以某种方式做出贡献的个人或法人。

注：贡献行为包括但不限于问题解答、撰写文档、提交代码、捐款。

3.5

源代码 source code

以适合于作为汇编程序、编译程序或其他转换程序输入的形式表示的计算机指令和数据定义。

[来源：GB/T 11457—2006，2.1541，有修改]

4 缩略语

下列缩略语适用于本文件。

API:应用程序接口(Application Programming Interface)
CPU:中央处理器(Central Processing Unit)
RPO:恢复点目标(Recovery Point Objective)
RTO:恢复时间目标(Recovery Time Objective)

5 金融行业开源软件测评体系

金融行业开源软件测评体系主要分为测评模型和测评方法两部分。

测评模型具有一级评估属性、二级评估属性、测评指标三个层次。评估属性指开源软件在某一方面的特征,测评指标是反映开源软件在该方面特征表现好坏的具体测评项目。通过对所有评估属性进行综合考察后,得到开源软件的测评结果。

测评方法对测评过程中的权重设定、评分计算和等级评价进行了说明。金融行业开源软件测评模型评估属性见表1。

表1 金融行业开源软件测评模型评估属性

序号	一级评估属性	二级评估属性
1	开源许可证	开源许可证信息
		开源许可证权利和限制
		开源许可证兼容性
2	行业认可度	商业版本
		商业化实践或应用案例
		第三方测评结果
3	产品活力	产品活跃度
		社区活跃度
		代码生命周期
		关注度
		参与软件开发的企业情况
4	服务支持	文档质量
		运维服务
		支持工具
5	安全性	漏洞情况
		入侵检测与防御
		保密性
		完整性
		抗抵赖性
6	兼容性	运行环境兼容
		接口兼容
		数据兼容

表 1　金融行业开源软件测评模型评估属性（续）

序号	一级评估属性	二级评估属性
7	可维护性	模块化
		规范性
		可管理性
8	可扩展性	资源扩展
		架构扩展
		二次开发
9	功能性	功能完备性
		功能正确性
		功能适合性
		功能合规性
10	可靠性	成熟性
		可用性
		容错性
		易恢复性
11	易用性	易理解性
		易使用性
12	性能效率	处理效率
		容量
		资源占用

6　金融行业开源软件测评模型

6.1　开源许可证

6.1.1　开源许可证信息

测评指标如下：

a）　开源许可证，即开源软件源代码中有无许可证；

b）　不同许可证文件数量，即开源软件源代码中不同许可证文件的数量；

c）　双授权，即是否存在开源版本和商业授权版本。

6.1.2　开源许可证权利和限制

测评指标如下：

a）　基于开源软件提供服务，即许可证条款对于基于开源软件产品对外提供服务方面的权利和限制；

b）　许可证变更，即许可证条款对于衍生产品许可证变更方面的权利和限制；

c）　闭源限制，即许可证条款对于衍生产品变更代码及变更后在开源方面的权利和限制；

d） 商业应用，即许可证条款对于发布商业衍生产品方面的权利和限制；
e） 版权归属，即许可证条款对于开源软件及其衍生产品版权归属方面的权利和限制；
f） 专利归属，即许可证条款对于开源软件及其衍生产品专利归属方面的权利和限制；
g） 商标归属，即许可证条款对于开源软件及其衍生产品商标归属方面的权利和限制。

6.1.3 开源许可证兼容性

测评指标如下：
a） 许可证内部兼容冲突，即软件产品包含多个开源软件许可证时，不同许可证条款的冲突情况；
b） 许可证外部兼容冲突，即所使用开源软件的许可证条款与其他相关软件或产品的许可证、软件使用者商业目标的冲突情况。

6.2 行业认可度

6.2.1 商业版本

测评指标如下：
a） 版本数量，即开源软件的商业版本数量及相应的收费情况；
b） 发行企业，即发行开源软件商业版的企业数量和规模。

6.2.2 商业化实践或应用案例

测评指标如下：
a） 案例数量，即应用开源软件的商业化实践案例数量；
b） 应用企业，即应用开源软件的企业信息（规模、行业等）；
c） 上线时间，即应用开源软件的业务上线时间（精确至年月）；
d） 运行时间，即应用开源软件的业务运行时间；
e） 应用重要程度，即按照行业属性的级别、类别等重要程度信息，区分应用案例的重要性情况。

6.2.3 第三方测评结果

测评指标如下：
a） 测评机构，即测评机构的权威性和影响力；
b） 测评结果，即测评机构对开源软件的评估结果，如整体评价、技术特色和解决的问题等。

6.3 产品活力

6.3.1 产品活跃度

测评指标如下：
a） 近一年版本发布情况，即开源软件近一年的版本发布数量和版本号；
b） 近三个版本发布周期，即开源软件近三个版本的发布时间间隔；
c） 近一年代码贡献量，即开源软件近一年每季度的代码贡献量变化情况；
d） 近一年提交数量，即开源软件近一年每季度的提交数量变化情况；
e） 近一年提交和修复问题数量，即开源软件近一年每季度的提交问题和修复问题数量变化情况。

6.3.2 社区活跃度

测评指标如下：
a） 开源社区受关注情况，即开源软件受到关注、加星和拷贝等操作的情况；

b) 提交与合并请求数量，即开源软件的提交与合并请求数量；
c) 近三年贡献者数量，即开源软件近三年每季度贡献者数量变化情况；
d) 近三年提交数量，即开源软件近三年每季度提交数量变化情况；
e) 贡献者等级分布情况，即开源软件贡献者数量及其等级分布情况；
f) 社区类型，社区类型包括由第三方中立基金会建设、企业联合共建、单一企业建设和个人建设等；
g) 社区管理制度，即社区管理制度的规范情况，包括版本更新制度、贡献管理制度、公共渠道沟通和反馈制度等；
h) 沟通渠道，即开源软件社区或托管平台提供的沟通渠道情况。

6.3.3 代码生命周期

测评指标如下：
a) 所有版本号，即开源软件全生命周期的版本发布情况；
b) 版本发布周期，即开源软件全生命周期的版本发布间隔和项目寿命；
c) 版本代码行数，即开源软件全生命周期各个版本的代码量变化情况。

6.3.4 关注度

测评指标如下：
a) 文献数量，即开源软件相关的文献数量(包括学术文献、专利等)；
b) 书籍数量，即开源软件相关的实体书和电子书数量；
c) 微信、微博等媒体平台传播的文章数量，即开源软件相关的微信、微博等媒体平台传播的文章数量；
d) 论坛网页数量，即开源软件相关的论坛网页数量；
e) 搜索引擎检索结果数量，即开源软件相关词条在搜索引擎的检索结果数量；
f) 技术社区检索结果数量，即开源软件相关词条在技术社区的检索结果数量；
g) 网络百科全书信息，即开源软件相关词条在网络百科全书的记录情况。

6.3.5 参与软件开发的企业情况

测评指标如下：
a) 企业信息，即对开源软件源码有贡献的企业信息(规模、行业等)；
b) 企业数量，即对开源软件源码有贡献的企业数量。

6.4 服务支持

6.4.1 文档质量

测评指标如下：
a) 文档数量，即开源软件源码中的说明文档和帮助文档的数量；
b) 文字规模，即开源软件源码及官网中的说明文档和帮助文档的文字规模；
c) 文档覆盖范围，即开源软件源码及官网中的文档覆盖范围。

6.4.2 运维服务

测评指标如下：
a) 商业支持，即服务商在协助运维或托管运维方面的支持情况；

b） 服务提供商数量，即提供协助运维或托管运维的服务商数量。

6.4.3 支持工具

测评指标如下：

a） 开发语言种类，即开源软件所支持的开发语言种类及占比；

b） 作为组件工具支撑其他框架情况，即开源软件作为通用组件支撑其他框架（如云计算、大数据等）的情况；

c） 支持开发、测试和使用该软件的工具情况，即支持开源软件开发、测试和使用的相关工具信息。

6.5 安全性

6.5.1 漏洞情况

测评指标如下：

a） 现有漏洞情况，即开源软件现有已暴露的漏洞及其漏洞安全等级、已经被发现（有可能未被公开）而官方还没有相关补丁的漏洞（即零日漏洞，0Day 漏洞）和漏洞密度（包括时间密度和规模密度）的情况；

b） 已修复漏洞情况，即开源软件已修复的漏洞及其漏洞安全等级，以及历史上是否造成生产事故及其社会影响的情况；

c） 潜在漏洞情况，即开源软件的潜在漏洞数量及其危险程度，如代码安全扫描后是否存在严重漏洞或高危漏洞等的情况。

6.5.2 入侵检测与防御

测评指标如下：

a） 用户身份认证和鉴权，即开源软件对终端用户权限控制和鉴权的支持情况；

b） 抵御非法入侵或攻击，即开源软件对已经尝试、正在发生或已经发生的入侵或攻击行为快速作出响应和防御的能力；

c） 非授权访问控制，即开源软件对非授权访问的控制和隔离能力；

d） 连接认证，即开源软件对网络连接的安全检测和认证机制。

6.5.3 保密性

测评指标如下：

a） 访问日志，即开源软件对访问行为的日志记录情况；

b） 敏感信息处理，即开源软件运行过程中的敏感信息处理和留存情况；

c） 数据传输或存储保密处理，即开源软件数据传输与存储过程中的保密处理情况；

d） 加密算法安全性，即开源软件所使用加密算法的安全性；

e） 国产密码算法支持，即开源软件使用国产密码算法或支持国产密码算法的情况。

6.5.4 完整性

测评指标如下：

a） 数据防篡改，即开源软件防止数据被篡改的能力；

b） 数据校验，即开源软件对非法数据和错误数据进行校验的能力。

6.5.5 抗抵赖性

测评指标如下：

a) 操作记录可审计，即开源软件记录和取证参与者操作的能力；
b) 操作记录防篡改，即开源软件防止参与者的操作记录被修改或删除的能力。

6.6 兼容性

6.6.1 运行环境兼容

测评指标如下：
a) 硬件或网络环境兼容，即开源软件在不同的硬件和网络环境中运行的兼容性；
b) 操作系统兼容，即开源软件在不同的操作系统以及同一操作系统的不同版本中运行的兼容性；
c) 终端兼容，即开源软件在不同的终端设备，如在服务器和移动终端中运行的兼容性。

6.6.2 接口兼容

测评指标如下：
a) 外部接口兼容，即开源软件与其他软件或系统进行交互的接口兼容性；
b) 版本接口兼容，即开源软件自身接口在不同版本间的兼容能力。

6.6.3 数据兼容

测评指标如下：
a) 外部数据兼容，即开源软件与其他软件或系统的数据可交换性；
b) 版本数据兼容，即开源软件不同版本间的数据兼容能力。

6.7 可维护性

6.7.1 模块化

开源软件结构及源代码组织设计的模块化程度。

6.7.2 规范性

测评指标如下：
a) 代码的规范性，即开源软件源代码编写的规范性；
b) 数据的规范性，即开源软件数据格式的规范性；
c) 注释的规范性，即开源软件源代码注释编写的规范性。

6.7.3 可管理性

测评指标如下：
a) 命令行管理工具，即开源软件提供命令行管理工具的情况；
b) 网站管理工具，即开源软件提供官方或第三方的可视化网站管理工具的情况；
c) 运行状态监控，即开源软件提供运行状态监控的情况；
d) 远程管理，即开源软件提供远程管理 API 等对其进行远程管理的情况；
e) 日志配置和管理，即开源软件对多级别日志配置和管理的支持情况。

6.8 可扩展性

6.8.1 资源扩展

测评指标如下：

a） 资源水平扩展，即开源软件对资源水平扩展的支持情况；
b） 资源扩展瓶颈，即开源软件存在资源扩展瓶颈（如关系数据库不可扩展等）的情况。

6.8.2 架构扩展

测评指标如下：
a） 分布式架构，即开源软件对分布式架构的支持情况；
b） 并行计算架构，即开源软件对并行计算架构的支持情况。

6.8.3 二次开发

测评指标如下：
a） 二次开发难易度，即开源软件是否支持二次开发以及开发的难易程度，如多语言支持等；
b） 二次开发兼容性，即开源软件二次开发后接口和数据的兼容性。

6.9 功能性

6.9.1 功能完备性

测评指标如下：
a） 功能完整性，即开源软件功能集对指定的任务和使用方目标的覆盖程度；
b） 功能依赖性，即开源软件功能对其他软件的依赖情况。

6.9.2 功能正确性

测评指标如下：
a） 符合预期情况，即开源软件功能与使用方预期结果的符合程度；
b） 数据并发能力，即开源软件在数据并发时保持功能正确的能力。

6.9.3 功能适合性

测评指标如下：
a） 功能适用性，即开源软件功能与应用场景结合的适用性；
b） 功能专有性，即开源软件专有功能与应用场景结合的能力。

6.9.4 功能合规性

开源软件遵循与功能性相关的标准、约定或法规以及类似规定的程度。

6.10 可靠性

6.10.1 成熟性

开源软件在具体应用场景提供需要功能的有效情况，如测试通过率等。

6.10.2 可用性

测评指标如下：
a） 平均故障间隔时间，即开源软件出现故障的平均间隔时间；
b） 有效服务时间率，即开源软件使用一段时间内提供有效服务的占比情况；
c） 累计失效时间，即开源软件使用一段时间内累计的失效时间；
d） 在线更新能力，即开源软件支持在线更新且更新后可用的能力；

e） 满负荷正常运行能力，即开源软件在满负荷情况下使用一段时间内正常运行的时间和占比。

6.10.3 容错性

测评指标如下：

a） 抵御误操作，即开源软件提供防止误操作的能力；

b） 抵御错误数据，即开源软件抵御错误数据的能力；

c） 节点容错性，即开源软件在部分节点故障后仍能对外提供服务的能力。

6.10.4 易恢复性

测评指标如下：

a） 故障修复时间，即开源软件出现故障后快速恢复正常服务的能力，如故障平均修复时间、RTO 等参数；

b） 数据恢复能力，即开源软件在故障情况下保证数据一致性和防丢失的能力，如 RPO 等参数。

6.11 易用性

6.11.1 易理解性

测评指标如下：

a） 可辨识性，即用户能够辨识开源软件是否适合需求的程度；

b） 应用示例，即针对支持的开发语言，开源软件提供可操作的应用示例包的情况。

6.11.2 易使用性

测评指标如下：

a） 安装和卸载，即开源软件提供常用操作系统的单机或集群部署以及卸载指导的情况；

b） 功能易使用，即开源软件功能易于使用和操作的程度；

c） 参数可配置，即开源软件的应用规模、数据空间大小等参数的可配置情况；

d） 系统集成方案，即开源软件提供与其他系统进行集成的方案指导情况；

e） 第三方插件，开源软件支持集成和使用第三方插件的情况。

6.12 性能效率

6.12.1 处理效率

测评指标如下：

a） 响应时间，即开源软件从接收指令到做出反应的时间间隔；

b） 吞吐率，即开源软件在单位时间内通过某通信通道或某个节点成功交付数据的平均速率。

6.12.2 容量

测评指标如下：

a） 并发用户数，即开源软件能够处理的最大并发用户数；

b） 并发请求数，即开源软件能够处理的最大并发请求数；

c） 事务或数据吞吐容量，即开源软件在多事务、大数据量等情况下的吞吐能力。

6.12.3 资源占用

测评指标如下：

a） CPU 占用情况，即开源软件稳定运行时 CPU 的占用情况；
b） 内存占用情况，即开源软件稳定运行时内存的占用情况；
c） 网络带宽占用情况，即开源软件稳定运行时网络带宽的占用情况；
d） 存储占用情况，即开源软件稳定运行时存储的占用情况。

7 金融行业开源软件测评方法

7.1 说明

金融行业开源软件测评过程中对评估属性和测评指标进行分级定义和分级运算，每一级有相应的权重体系，自下而上计算得出开源软件的量化评分值。实际测评时，将可量化的指标进行量化，不可量化的定性指标则采用专家评估法进行确定。另外，针对某些特殊指标可以设置“一票否决”权，如开源许可证中存在不满足应用需求的限制条件等。本文件测评模型中的评估属性和测评指标可结合具体开源软件特点进行合理增删。

以下给出参考测评方法，该测评方法采用由测评指标到一级评估属性，再到最终测评结果的两阶段计算方式。实际测评时可根据需求制定更适合的计算及评价方法，如将二级评估属性纳入阶段计算，用雷达图形式的多维度评价作为测评结果等。

7.2 权重设定

7.2.1 一级评估属性

一级评估属性的权重反映了金融机构对开源软件的关注重点，金融机构重点关注的评估属性具有更大权重值。通过专家评分的方式，调研开源软件各项一级评估属性的相对重要性，并用求平均和归一化的方法确定各一级评估属性的权重。

7.2.2 具体测评指标

具体测评指标的权重取决于该指标相对于相同一级评估属性下其他指标的重要性和可实施性，即该指标的相对重要性和可实施性是决定权重的关键要素。基于专家小组调研结果，通过相乘法计算得到测评指标的权重，即：

$$Z = X \times Y \qquad \cdots\cdots(1)$$

式中：

Z ——测评指标的权重；

X ——测评指标的重要性；

Y ——测评指标的可实施性。

7.3 评分计算

第一阶段，计算一级评估属性的评分值。将一级评估属性下各测评指标的评分值与相应权重相乘，再取平均值得到该一级评估属性的评分值，即：

$$T = \left(\sum_{i=1}^{n} U_i \times Z_i\right) / n \qquad \cdots\cdots(2)$$

式中：

T ——一级评估属性的评分值；

U_i——该一级评估属性下的第 i 个测评指标的评分值；

Z_i——该一级评估属性下的第 i 个测评指标的权重；

n ——该一级评估属性下的测评指标数量。

第二阶段，计算测评结果。开源软件的测评结果由第一阶段计算得到的一级评估属性评分值乘以相应权重后相加得出，即：

$$V=\sum_{j=1}^{m}(T_j \times W_j) \qquad \cdots\cdots(3)$$

式中：

V ——开源软件的测评结果；

T_j ——第 j 项一级评估属性的评分值；

W_j ——第 j 项一级评估属性的权重；

m ——一级评估属性数量。

两阶段的计算可以减弱由于属性选取的某些不合理因素导致测评结论的偏差，也可以充分体现开源软件中不同测评指标的权重比例。

7.4 等级评价

针对开源软件进行评价时，建议划分为 AAA、AA、A 和 B 四个评价等级，将开源软件的测评结果进行归一化处理后的通用划分方法见表 2，具体评分区间可根据实际需求灵活调整。金融机构应根据实际需求定期展开等级评价，以动态评估开源软件服务能力，等级评价方法见表 2。

表 2 等级评价方法

等级	评分区间
AAA	$0.90 \leqslant V \leqslant 1$
AA	$0.80 \leqslant V < 0.90$
A	$0.60 \leqslant V < 0.80$
B	$0 \leqslant V < 0.60$

参 考 文 献

[1] GB/T 11457—2006 信息技术 软件工程术语

[2] GB/T 19001—2016 质量管理体系 要求(ISO 9001:2015,IDT)

[3] GB/T 25000.10—2016 系统与软件工程系统与软件质量要求和评价(SQuaRE) 第10部分:系统与软件质量模型

[4] GB/T 25000.40—2018 系统与软件工程 系统与软件质量要求和评价(SQuaRE) 第40部分:评价过程

[5] SJ/T 11235 软件能力成熟度模型

[6] T/SIA 003—2019 软件产品评估标准

[7] 工业和信息化部软件与集成电路促进中心.开源软件成熟度评估及选型指南[M].北京:中国水利水电出版社,2011.